



Domain 3: Access Control Concepts

Security Controls:

- Safeguard or counter measure designed to preserve CIA triad.
- Limiting what Objects can be available to what Subjects according to rules.

Controls Overview:

- **Subjects**
 - Entities that request access to resources.
 - User, process, procedure, client, endpoint.
 - Should have permission that relates to its ability to access resources or services.
- **Objects**
 - Represent the asset or resources that subjects seek to access.
 - Server, process, a block of memory.
 - Anything that provides service to a user.
- **Rules** - Foundation of access control framework by defining the conditions under which access is granted or denied to Objects.

Defence in Depth:

Using multiple layers of security measures to protect networks, systems and data.

Least Privilege:

Principle of Least Privilege (POLP) is concept that involves granting users, programs, or processes only the **minimum levels of access** or permissions necessary to perform their required tasks.

Privileged Accounts:

Special accounts have elevated permissions and access rights beyond those of regular users.

Privileged Access management:

PAM is crucial subset of IAM

- **Identity and Access Management (IAM) -**

Manages who can access what in an organization. It's the general security process of verifying a user's identity (authentication) and giving them the correct permissions (authorization) for everyday access to digital resources.

- **Privileged Access Management (PAM) -**

A specialized part of IAM that secures and monitors accounts with powerful, administrative rights. It adds extra layers of protection and auditing for these critical accounts to prevent misuse.

Separation of Duties:

Based on no one person should control an entire high-risk process from start to finish.

Two person integrity - Known as two person rule or dual control, requires at least two authorized individuals to perform critical or sensitive tasks.

How users are provisioned:

- **New employee** - account created.
- **Change position** - account modified.
- **Separation of employment** - When employee leave company, their account must be disabled.
- Upon hiring or changing roles, a best practice is not copy user profile to new users.

Physical Controls:

Prevent unauthorised individuals from entering a physical site, such as workspace.

- **Environmental Design -**

Crime Prevention through Environmental Design (CPTED) approaches the challenge of creating safer workspaces through passive design elements.

- **Natural Surveillance:** Good lighting, open spaces, and windows so suspicious activity can be easily seen.
- **Natural Access Control:** Fences, landscaping, and pathways that guide people to the right entrances.
- **Natural Territorial Reinforcement:** Clear signs of ownership like company logos, maintained grounds, and boundaries.

- **Badge Systems and Gate Entry -**

- **Badge Systems:** Employee ID cards with RFID chips, smart cards, or magnetic strips that unlock doors.
- **Gate Entry Systems:** Turnstiles, keypads, or biometric scanners at entrances.

- **Monitoring Systems -**

- **Security Guards:** Human oversight who can make judgment calls and respond to unusual situations.
- **CCTV Cameras:** 24/7 video surveillance that records everything and acts as a deterrent.
- **Alarm Systems:** Detect unauthorized entry and alert security personnel or law enforcement.

- **Physical Barriers -**

- **Mantrap** - Two-doors gate, second opens after closing first.
- **Turnstiles** - Spinning gate, allows entering one person at a time.
- **Fences** - Wired barriers like wall.

- Bollards - Prevents vehicles entering.

Log Terminology:

- **Anomaly:** Spotting something unusual or unexpected in system logs that doesn't match the normal pattern, which can signal a security threat or performance issue.
- **Consolidation:** Bringing all log data from different devices and applications into one central place for easier review and analysis.
- **Retention:** The practice of storing log data for a specific period based on rules for compliance, security investigations, or operational needs.

Logical Controls:

Electronic methods that limit someone from getting access to systems.

Discretionary Access Control (DAC):

DAC Policy specifies that a subject who has been granted access to information can do one or more of the following:

- Pass the information to other subjects or objects.
- Grants its privilege to other subjects.
- Change security attributes on subjects, objects, information systems or system components.
- Choose security attributes to be associated with newly created objects.
- Change the rules governing access control; mandatory access controls restrict this capability.

Mandatory Access Control:

MAC Policy is a security approach that applies uniform rules across all subjects and objects within an information system.

1. Only designated security admins can modify security rules.
2. The organization assigns specific privileges to subjects for subset of objects.
3. Subjects are restricted from:
 - Sharing information with unauthorised parties.
 - Granting their privileges to others.
 - Altering security attributes of system componets.
 - Selecting security attributes for new or modified objects.
 - Changing Access Control rules.

Role based Acces Control:

Provides each worker privileges based on role they have in the organization.

Privilege creep - is when someone gets more access rights than they need for their job over time.